

Data flow & residency

The honest map of what personal data the platform processes and where it goes. Everything else in this pack is downstream of this document — keep it accurate.

Draft for review, not legal advice. See `README.md` .

Roles

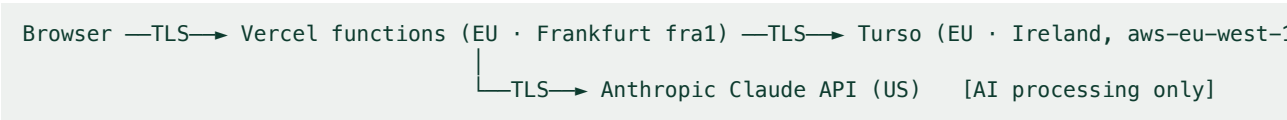
For a sprint engagement, the **client** (e.g. BeFrank) is the **controller** (verwerkingsverantwoordelijke) — it decides the purpose. **Unlockt** is the **processor** (verwerker), acting on the client's documented instructions. Anthropic, Vercel and Turso are **sub-processors** (see `02_subprocessor-list.md`).

What personal data the platform holds

Data subject	Personal data	Sensitivity
Client crew (client employees doing the intake)	Name, role; free-text pre-work answer; AI-interview transcript (their opinions about their employer/colleagues); self-assessment answers (numeric)	Free-text answers can be career-sensitive in an employment context. Not Art. 9 special-category data.
Uploaded documents	Whatever the crew uploads (research, decks, board reports) — may contain third-party personal data and confidential business data	Variable. Clients are instructed not to upload special-category data (health, etc.).
Test panel (consumers from the target group)	First name + age band (e.g. "Sanne, 34"); verbal reactions/quotes; 1–5 scores	Panelists may volunteer personal financial circumstances. Minimised by design: first name + age only, no full identification.

The market-research brief is about the company, not data subjects, and contains only public-source information — negligible personal data.

Where the data goes



Layer	Provider	Location	What it handles
App compute	Vercel	EU — Frankfurt (fra1)	Runs the application; transient processing only, no primary data store
Database (at rest)	Turso	EU — Ireland (aws-eu-west-1)	The system of record: all sprint data
AI processing	Anthropic (Claude API)	US	Receives the text sent to AI features; see below

The US transfer (Anthropic) — the one flow to disclose clearly

The AI features send text to Anthropic's first-party Claude API, which processes and stores at-rest **in the United States**. The first-party API has **no EU data-residency option** (EU processing for Claude exists only via AWS Bedrock or Google Vertex, which this platform does not currently use).

What is sent to Anthropic:

- **AI interview** → the crew member's free-text answers.
- **Document analysis** → the full text of each uploaded document.
- **Readout** → the panel's quotes and scores.
- **The research brief, pre-read, canvas suggestions, prototype build and**

Ask-the-library send company/derived content — minimal to no data-subject personal data.)

Transfer safeguards:

- **Standard Contractual Clauses** in Anthropic's DPA are the transfer mechanism. [△] **CONFIRM** the exact SCC module/version against the live DPA.
- **Not training**. Anthropic does not use commercial/API data to train models.
- **Retention: 30 days**. Anthropic auto-deletes API inputs/outputs within 30 days. **Note:** the current model (`claude-opus-4-8`) mandates 30-day retention and **cannot** run under Zero-Data-Retention — so a true "zero retention" claim is **not** available on this model today. Data tied to a flagged policy violation may be kept up to 2 years.
- [△] **CONFIRM** Anthropic's EU-US Data Privacy Framework status at dataprivacyframework.gov/list (sources conflict — do not state it unconfirmed).

Mitigations already in place

- **App** compute moved from the US default to **EU (Frankfurt)** — `vercel.json` pins `fra1` .
- **Database** is in the **EU (Ireland)** by region choice.
- **Personal data** is **minimised** before it reaches the AI (panelists are first-name + age; the assessment sends numbers, not identities).

The EU-residency upgrade path (a decision, not a fix)

If a client requires AI processing to stay in the EU, the AI layer can be moved to **Claude on AWS Bedrock (EU region)** or **Google Vertex AI** (`region:"eu"`). That is an architecture change (different SDK/auth, model-id changes, model-availability check) — scope it only if a client makes it a condition. Documented here so the option is on the table, not buried.

Legal basis (controller to confirm)

The controller (client) sets the legal basis. Typically: the engagement contract / legitimate interest for the crew, and **explicit consent** for the consumer test panel (with incentive disclosure — see `08_privacy-notices-NL.md`).